

SOC 2 Type 2 Gap Analysis

FridayReport.AI
Enterprise Project Portfolio Management

Date: March 12, 2026
Scope: All Five Trust Service Criteria
Assessment: Application-Level Controls
Classification: Confidential

Executive Summary

FridayReport.AI has a solid foundation for SOC 2 compliance with strong audit logging, role-based access control, and multi-provider authentication already in place. However, several critical gaps remain across all five criteria — most notably the absence of MFA, weak password policies, no session idle timeout, missing security headers, no health check endpoints, and no formal data retention enforcement.

This document details every control area across all five Trust Service Criteria (Security, Availability, Processing Integrity, Confidentiality, Privacy), identifies what is currently implemented, and highlights what is missing or needs improvement.

1. SECURITY (CC — Common Criteria)

CC6.1 — Logical Access Controls

- [+] **User authentication** — Implemented
Email/password, Google OAuth, Microsoft OAuth, Replit OAuth, Magic Links
- [] **Multi-factor authentication (MFA)** — Missing
No MFA/2FA implementation. Critical gap for SOC 2.
- [?] **Password complexity policy** — Weak
Only 6-char minimum. No uppercase, number, or special character requirements.
- [] **Account logout** — Missing
No mechanism to lock accounts after repeated failed login attempts.
- [+] **Role-based access control (RBAC)** — Implemented
System roles (super_admin, marketing, user) and org roles (owner, org_admin, team_member).
- [+] **Org-level access enforcement** — Implemented
userHasOrgAccess middleware on all org-scoped endpoints.
- [+] **API token authentication** — Implemented
Bearer token auth with api_tokens table.
- [] **Force password change** — Missing
No mechanism to force password change on first login or after admin reset.

CC6.2 — Session Management

- [+] **Secure session storage** — Implemented
PostgreSQL-backed sessions via connect-pg-simple.
- [+] **Secure cookie flags** — Implemented
httpOnly: true, secure: true (production), sameSite: lax.
- [+] **Session logout** — Implemented
Endpoint destroys session and clears cookie.
- [] **Session idle timeout** — Missing
No inactivity timeout. Sessions last 30 days regardless of activity.
- [] **Concurrent session limits** — Missing
No limit on simultaneous sessions per user.

CC6.3 — Encryption

- [+] **HTTPS/TLS in transit** — Implemented
Enforced by hosting platform (Replit).
- [+] **Password hashing** — Implemented
crypto.scrypt with unique 16-byte salt, 64-byte derived key.
- [+] **Token encryption at rest** — Implemented
AES-256-GCM for OAuth tokens (Microsoft Planner, integrations).
- [?] **Database encryption at rest** — Platform-dependent
Managed by PostgreSQL hosting provider; not application-controlled.
- [?] **Sensitive field encryption** — Partial
Only OAuth tokens encrypted. Financial data, PII in exports unencrypted.

CC6.6 — Security Event Monitoring

- [+] **API request logging** — Implemented
All requests logged with method, path, status, duration, user ID, IP.
- [+] **User activity logging** — Implemented
user_activity_logs tracks high-level actions with IP and user agent.
- [+] **Error logging** — Implemented
error_logs table captures stack traces, request context, user info.
- [] **Login success/failure logging** — Missing
No dedicated security event log. Failed logins not tracked.
- [] **Privilege escalation tracking** — Missing
Role changes not logged in a security-specific audit trail.
- [] **Security event alerting** — Missing
No automated alerts for suspicious activity.

CC6.7 — Security Headers

- [!] Content-Security-Policy** — Partial
Only frame-ancestors set (for Teams). No script-src, style-src.
- [] Strict-Transport-Security (HSTS)** — Missing
Not set in application.
- [] X-Content-Type-Options** — Missing
Not set.
- [] Referrer-Policy** — Missing
Not set.
- [] Permissions-Policy** — Missing
Not set.

CC6.8 — Rate Limiting & DoS Protection

- [!] Auth endpoint rate limiting** — Partial
Custom in-memory limit on magic link/passwordless only (3 req/15 min).
- [] Login endpoint rate limiting** — Missing
No rate limit on password login endpoint.
- [] General API rate limiting** — Missing
express-rate-limit is a dependency but not applied.
- [] Bot protection** — Implemented
Honeypot mechanism and submission time validation on auth forms.
- [] File upload limits** — Implemented
50MB for project files, 5MB for images.

CC7.2 — CSRF Protection

- [] CSRF token validation** — Missing
No CSRF tokens. Relies solely on SameSite: Lax cookie attribute.

2. AVAILABILITY (A1)

A1.1 — System Monitoring

- [] **Health check endpoint** — Missing
No /health or /status endpoint.
- [] **Uptime monitoring** — Missing
No automated uptime tracking or alerting.
- [!] **Performance monitoring** — Partial
SuperAdmin shows API response times, but no persistent uptime metrics.
- [!] **Database health monitoring** — Partial
SuperAdmin database view exists but no persistent health history.

A1.2 — Incident Management

- [] **Incident tracking system** — Missing
No formal incident management. Help tickets exist but not incident-specific.
- [] **Incident severity classification** — Missing
No severity levels or response SLAs defined.
- [] **Incident timeline / root cause** — Missing
No structured incident record-keeping.
- [] **Post-incident review** — Missing
No process or tooling for post-mortems.

A1.3 — Recovery & Continuity

- [] **Graceful shutdown** — Missing
No SIGTERM/SIGINT handling. DB connections not closed cleanly.
- [!] **Automated backups** — Platform-dependent
No application-level backup jobs. Relies on hosting provider.
- [] **Backup verification** — Missing
No mechanism to verify backup integrity.
- [] **Disaster recovery testing** — Missing
No tooling for DR testing or documentation.

A1.4 — Maintenance Management

- [] **Maintenance window scheduling** — Missing
No ability to schedule or announce maintenance windows.
- [] **User notifications for downtime** — Missing
No maintenance banner or pre-announcement system.

3. PROCESSING INTEGRITY (PI1)

PI1.1 — Input Validation

- [+] **Schema validation (Zod)** — Implemented
Extensive Zod schemas on all write paths, client and server.
- [+] **Database constraints** — Implemented
Unique indexes, foreign keys, NOT NULL constraints throughout.
- [+] **Error classification** — Implemented
classifyError maps PostgreSQL codes and Zod errors to HTTP responses.
- [!] **Validation failure logging** — Missing
Failures returned to client but not logged for compliance review.

PI1.2 — Transaction Integrity

- [!] **Database transactions** — Partial
Used in billing. Many multi-table writes not wrapped in transactions.
- [!] **Idempotency handling** — Partial
Billing uses requestId. No general idempotency middleware.
- [!] **Duplicate detection** — Partial
Upsert patterns in some operations. No comprehensive guard.

PI1.3 — Processing Completeness

- [!] **Bulk operation tracking** — Missing
Import/export operations lack comprehensive success/failure tracking.
- [!] **Data integrity verification** — Missing
No scheduled jobs for orphaned records or integrity violations.
- [!] **Processing error monitoring** — Partial
Errors logged but no dashboards for processing error trends.

PI1.4 — Output Accuracy

- [!] **Report generation validation** — Partial
Reports from live queries; no checksums or validation on output.
- [!] **Export data verification** — Missing
No row count or checksum verification on data exports.

4. CONFIDENTIALITY (C1)

C1.1 — Data Classification

- [] Data classification labels** — Missing
No formal system (Public/Internal/Confidential/Restricted).
- [] Classification-based access** — Missing
No access restrictions based on data sensitivity level.
- [] Visual classification indicators** — Missing
No badges or labels showing data sensitivity in UI.

C1.2 — Access to Confidential Information

- [] Prg-scoped data isolation** — Implemented
All queries filter by organization ID. Multi-tenant isolation enforced.
- [] User data sanitization** — Implemented
sanitizeUser strips password hashes, tokens, API keys from responses.
- [] API key masking** — Implemented
Custom API keys masked (first/last 4 chars) in responses.
- [] Data access audit logging** — Missing
No tracking of who viewed sensitive data.

C1.3 — Data Retention & Disposal

- [] Data retention policies** — Missing
No configurable retention periods for any data type.
- [] Automated data cleanup** — Missing
No scheduled purge of old logs, expired tokens, or sessions.
- [] Expired token cleanup** — Missing
Magic link, password reset, invitation tokens never purged.
- [!] Session cleanup** — Partial
connect-pg-simple may auto-prune, but not explicitly configured.

5. PRIVACY (P1)

P1.1 — Privacy Notice & Consent

- [✓] **Privacy policy page** — Implemented
Dedicated Privacy Statement page outlining data practices.
- [✓] **User consent tracking** — Implemented
user_consent table with versioned records. Terms consent modal.
- [✗] **Consent withdrawal** — Missing
No mechanism for users to withdraw previously given consent.
- [!] **Consent change history** — Partial
Records stored but no UI for users to view consent history.

P1.2 — Right to Access & Portability

- [!] **Data export for users** — Partial
Excel/CSV exports for timesheets, issues. No "export all my data" feature.
- [✗] **Personal data inventory** — Missing
No single view showing what personal data the system holds.

P1.3 — Right to Erasure

- [✓] **User data deletion** — Implemented
Hard delete function removes user records, nullifies references.
- [!] **Anonymization** — Partial
Hard delete nullifies FKs but doesn't replace PII with anonymized values.
- [✗] **Erasure certification** — Missing
No formal certificate when user data is erased.

P1.4 — Privacy Preferences

- [!] **Notification preferences** — Partial
Org-level channel toggles. No per-user fine-grained preferences.
- [✗] **Privacy preference center** — Missing
No user-facing page for managing privacy and data sharing settings.

Priority Summary

Critical Gaps (Must Fix for SOC 2)

- 1. No MFA/2FA — Most auditors will flag this as a critical finding
 - 2. Weak password policy — 6-char minimum is insufficient
 - 3. No account lockout — Allows unlimited brute-force attempts on login
 - 4. No session idle timeout — 30-day sessions without activity check
 - 5. Missing security headers — HSTS, X-Content-Type-Options, Referrer-Policy
 - 6. No security event audit log — Login failures, role changes not tracked
 - 7. No health check endpoints — Required for availability monitoring evidence
 - 8. No data retention enforcement — Logs and expired tokens accumulate indefinitely
 - 9. No graceful shutdown — Risk of data corruption on restart

Important Gaps (Expected by Most Auditors)

- 10. No CSRF token protection
 - 11. No general API rate limiting
 - 12. No incident management system
 - 13. No data classification system
 - 14. No data access audit logging
 - 15. No validation failure logging
 - 16. Transaction wrappers missing on many multi-table operations
 - 17. No formal data integrity verification

Recommended Enhancements (Strengthens Audit Posture)

- 18. Concurrent session limits
 - 19. Privacy preference center
 - 20. Erasure certification
 - 21. Compliance admin dashboard
 - 22. Access review workflow
 - 23. Policy acknowledgment tracking
 - 24. Processing completeness verification for

Existing Strengths

The application has significant existing controls that will serve as strong evidence during an audit:

- 13 audit/log tables across activity, API requests, billing, timesheets, change logs, and error tracking
 - Multi-provider OAuth (Google, Microsoft, Replit) with secure token handling
 - Comprehensive RBAC with organization-level data isolation
 - AES-256-GCM encryption for sensitive integration tokens
 - Zod schema validation on all write paths (client and server)
 - SuperAdmin monitoring dashboard with API analytics and performance metrics
 - Soft-delete with recycle bin for data recovery
 - Full user hard-delete capability supporting right-to-erasure
 - Bot protection (honeypot mechanism) on authentication forms
 - Versioned consent tracking for privacy compliance
 - Timesheet audit engine with comprehensive action logging
 - Change log tables tracking before/after state for projects, tasks, issues
 - Billing audit logs tracking subscription and seat changes

This assessment covers application-level controls only. Infrastructure controls (network security, physical security, backup procedures, hosting provider certifications) should be assessed separately with your cloud provider's compliance documentation.

